



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de Redes y Sistemas

TEMA 3

CONFIGURACION DE SISTEMAS DE ACCESO Y AUTENTICACIÓN DE PERSONAS

Alberto Diéguez Álvarez

Tabla de contenido

Caso práctico.....	3
Apartado 1: Tarea de investigación aplicada.....	3
1. Identificación de tres servicios reales	3
Qué tipos de factores implementan realmente (no teoría).....	4
Cómo gestionan el proceso de recuperación de la cuenta.	6
Qué ventajas aportan frente a mecanismos convencionales.	8
Qué inconvenientes presentan en el uso diario.	8
2. Análisis de un incidente documentado de seguridad Investiga un caso real en el que haya fallado un mecanismo 2FA o MFA (phishing sofisticado, SIM swapping, bypass biométrico, prompt bombing...).	9
Qué mecanismo falló.....	9
Qué vulnerabilidad se explotó.	9
Si consideras que hoy podría repetirse.....	9
Qué habrías diseñado tú para evitarlo.	9
Apartado 2: Evaluación práctica.....	10
1. Activa dos métodos distintos de autenticación Puede ser SMS, TOTP, llave física, notificación push, biometría, etc.	10
El proceso de activación (con capturas propias).	10
Cualquier dificultad encontrada.....	13
Qué información adicional pide el sistema.....	13
Cómo se comporta si te equivocas o intentas un acceso desde un dispositivo nuevo.	13
2. Prueba de comportamiento ante eventos poco comunes Simula estas tres situaciones:.....	14
Acceso desde otro país mediante VPN.	14
Introducción repetida de contraseñas incorrectas.	16
Intento de acceso desde un dispositivo desconocido. Describe la reacción del sistema. ..	17
Indica si te parece suficiente y por qué.	17
Añade observaciones personales que no se puedan deducir sin hacer la prueba.	18
Apartado 3: Diseño de una propuesta de autenticación para un entorno real.....	18
Tipos de usuarios.	18
Dispositivos utilizados.	18
Datos sensibles que gestionan.	18
Riesgos más probables.	18
Qué factores usaría cada tipo de usuario.	18
Qué factores no usarías y por qué.	18
Cómo sería la política de recuperación de acceso.	19
Un diagrama sencillo del proceso de autenticación (hecho por ti, a mano o con herramienta).	19

Caso práctico

El director de seguridad de una empresa tecnológica ha detectado que, aunque los empleados conocen los tipos de factores de autenticación, muchos no comprenden realmente **cómo funcionan en la práctica, qué vulnerabilidades reales presentan, ni cómo elegir el mecanismo adecuado según el contexto**. Té ha pedido un informe que incluya **investigación aplicada, pruebas prácticas y propuestas de mejora para el plan interno de autenticación reforzada**.

¿Qué te pedimos que hagas?

Apartado 1: Tarea de investigación aplicada

Una vez conocidos los diferentes factores de autenticación, deberás realizar una investigación en profundidad que incluya:

1. Identificación de tres servicios reales

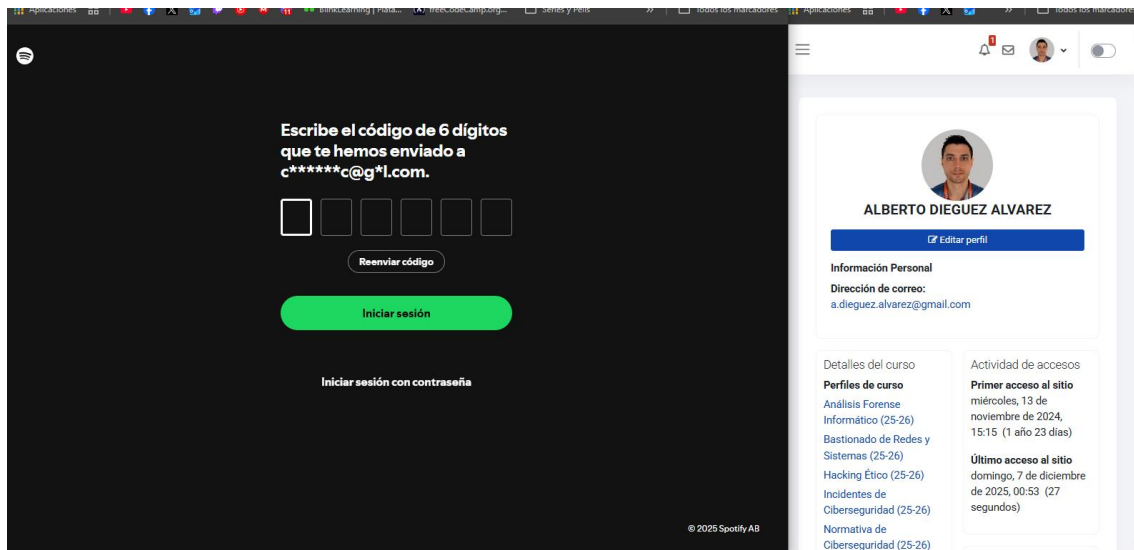
Selecciona tres servicios que tú utilices (correo, cloud, red social, repositorio, etc.) y explica:

Escojo:

- **Spotify**
- **Gmail**
- **Facebook**

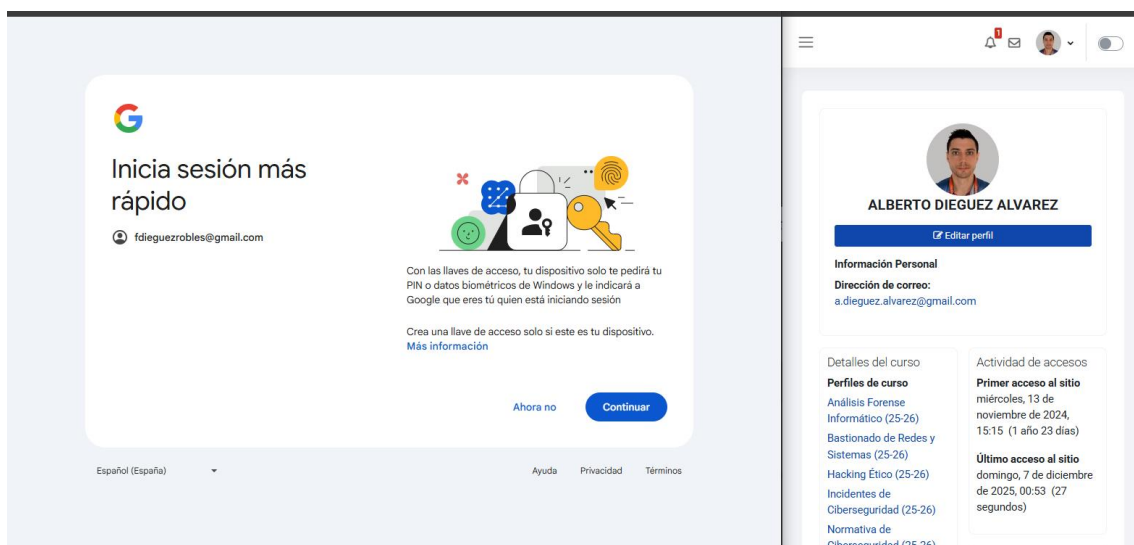
Qué tipos de factores implementan realmente (no teoría).

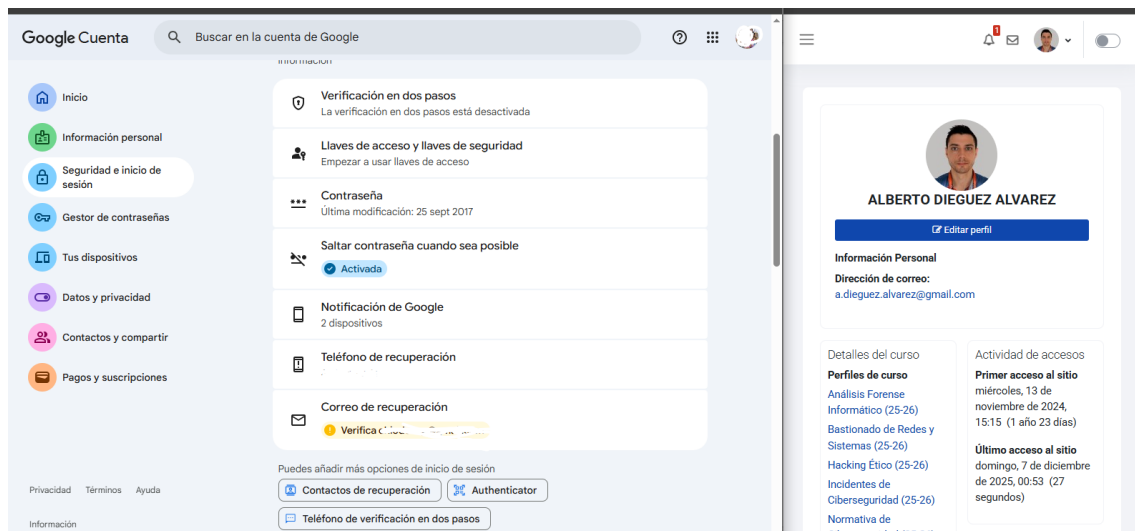
- **Spotify:**



Implementa verificación 2-step, es decir envía un código a tu email para verificar el acceso.

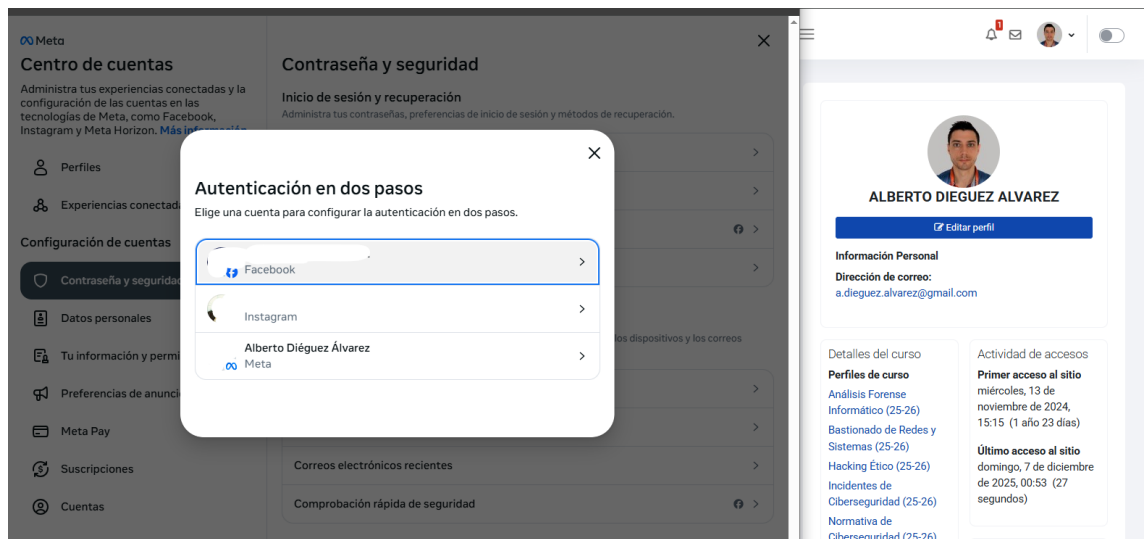
- **Gmail:**





Gmail solicita también verificación 2-step, tienes varias opciones a configurar, por correo o por sms.

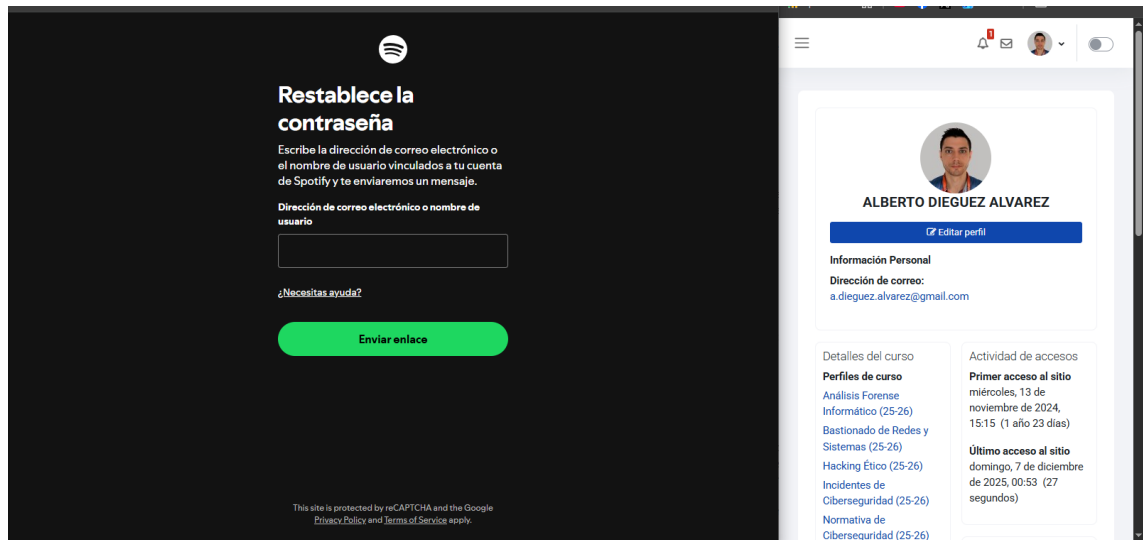
- Facebook:



Facebook, tiene la configuración para poner la autenticación en dos pasos.

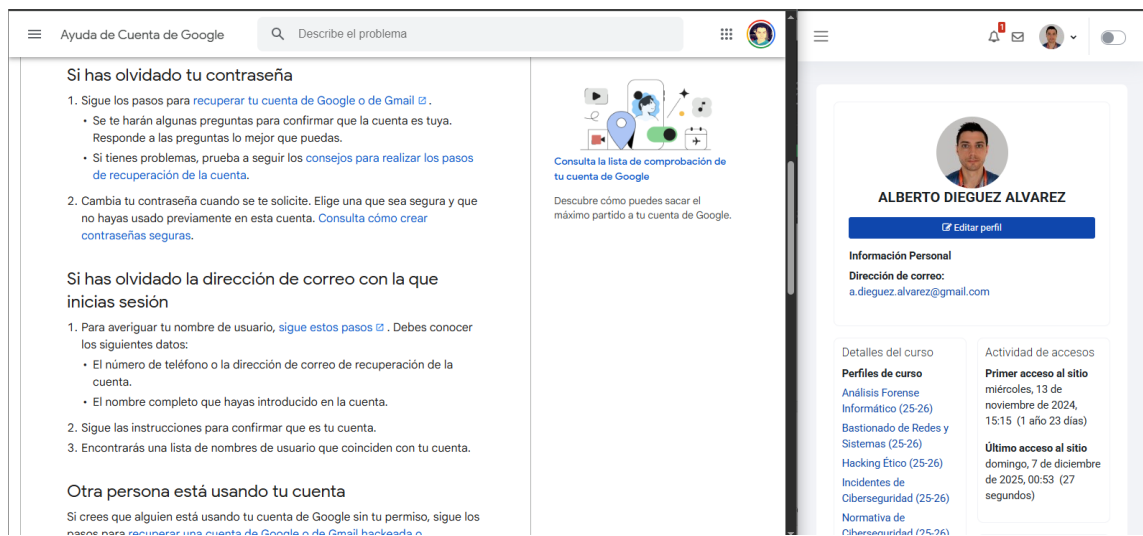
Cómo gestionan el proceso de recuperación de la cuenta.

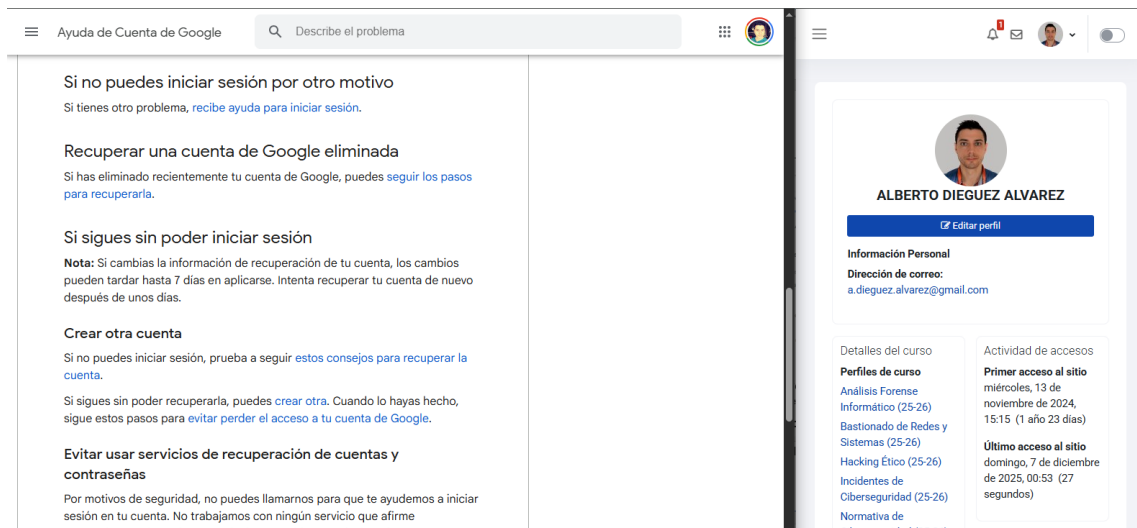
- Spotify:



La recuperación de cuenta es por email.

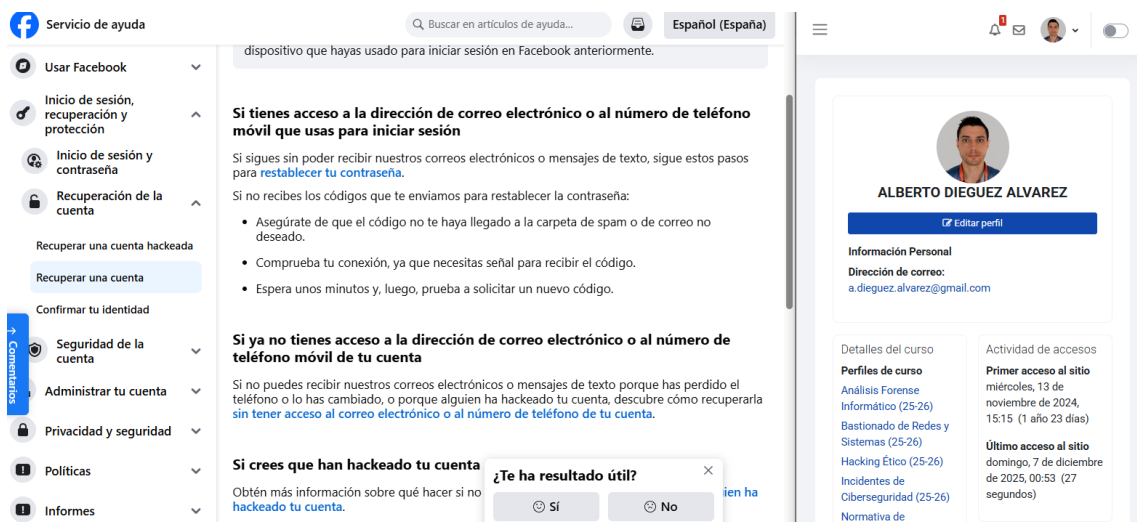
Gmail:





Gmail ofrece varias formas de recuperar la cuenta, desde códigos de envío por email o por sms hasta preguntas relacionadas con tu información etc...

Facebook:



Al igual que Gmail, Facebook posee varios métodos, como email o teléfono.

Qué ventajas aportan frente a mecanismos convencionales.

- **Spotify:**

La recuperación por verificación de correo, suele ser fácil de aplicar por parte del usuario.

- **Gmail:**

Tiene muchas opciones, algunas mejores que otras. Pero al tener un amplio repertorio de opciones, seguro que alguno agrada al consumidor.

- **Facebook:**

Al igual que los otros, permite varias formas de recuperación, y además también permite acceso por llave física.

Qué inconvenientes presentan en el uso diario.

- **Spotify:**

Pocos, ya que la doble autenticación por correo es muy fiable y no me parece muy liosa para el usuario.

- **Gmail:**

Al tener autenticación de dos pasos por sms, tiene riesgo de SIM swap, es decir que te clones la SIM y la utilicen para autenticarse por ti.

- **Facebook:**

Al igual que Gmail, también tiene la misma vulnerabilidad.

Debes incluir al menos una captura de pantalla propia del menú o proceso de activación, evitando mostrar datos personales.
(La ausencia de capturas invalida el apartado.)

2. Análisis de un incidente documentado de seguridad

Investiga un caso real en el que haya fallado un mecanismo 2FA o MFA (phishing sofisticado, SIM swapping, bypass biométrico, prompt bombing...).

Debes explicar:

Busco casos de SIM swap en internet y me voy a basar en este:

https://www.xataka.com/seguridad/primera-demanda-sim-swapping-para-at-t-224-millones-dolares-despues-hackeo-robo-bitcoins?utm_source=chatgpt.com

Qué mecanismo falló.

El mecanismo que falló fue la teleoperadora AT&T. Ya que como se dice en la noticia, las operadoras se han vuelto el eslabón más débil de la cadena, y según declara el demandante: AT&T no hizo lo suficiente para proteger su número de teléfono.

Qué vulnerabilidad se explotó.

Como dice la noticia el SIM swapping es un secuestro de SIM y consiste en engañar a la operadora para que transfieran el número de teléfono de una persona a una tarjeta SIM controlada por otra persona, el atacante.

Si consideras que hoy podría repetirse.

Sí, aún a día de hoy el SIM swapping es frecuente en ámbitos crypto, ya que muchos servicios permiten 2FA con SMS.

Qué habrías diseñado tú para evitarlo.

Pues directamente anular SMS o llamada como 2FA, y evitar esa vulnerabilidad que no depende de nosotros, si no de la operadora.

Y para estos temas de crypto o incluso cuentas bancarias, recomendaría usar llaves de acceso físicas, como se comenta en esta noticia:

<https://www.xataka.com/seguridad/google-asegura-que-este-pequeno-dispositivo-20-dolares-ha-evitado-que-sus-85-000-empleados-hayan-sido-victimas-phishing>

Debes aportar **la fuente del caso real** y un **análisis personal**, no una descripción genérica.

Apartado 2: Evaluación práctica

Realiza las siguientes acciones de forma manual en dos servicios diferentes:

1. Activa dos métodos distintos de autenticación

Puede ser SMS, TOTP, llave física, notificación push, biometría, etc.

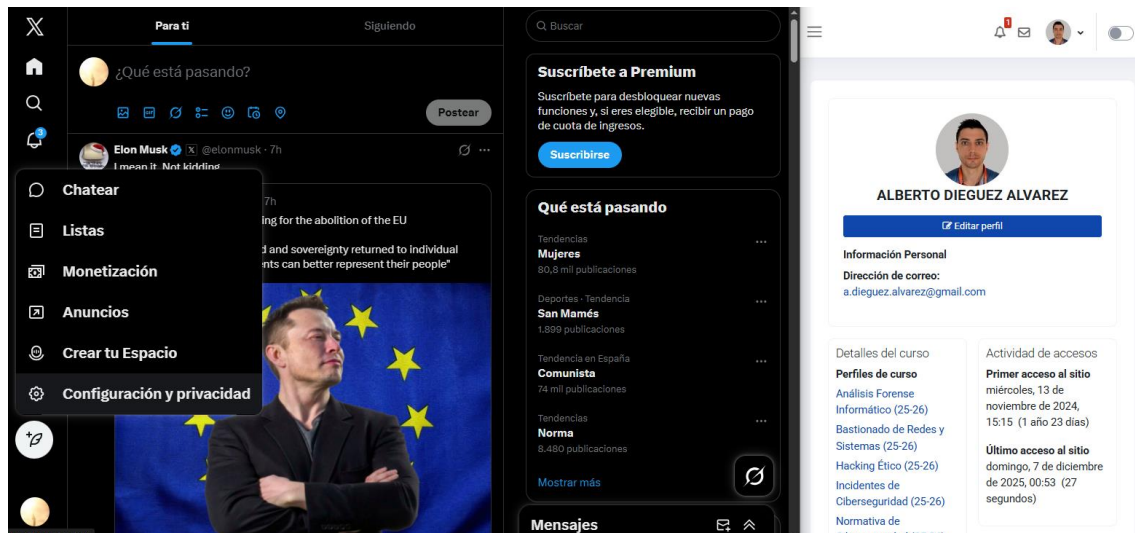
Documenta:

El proceso de activación (con capturas propias).

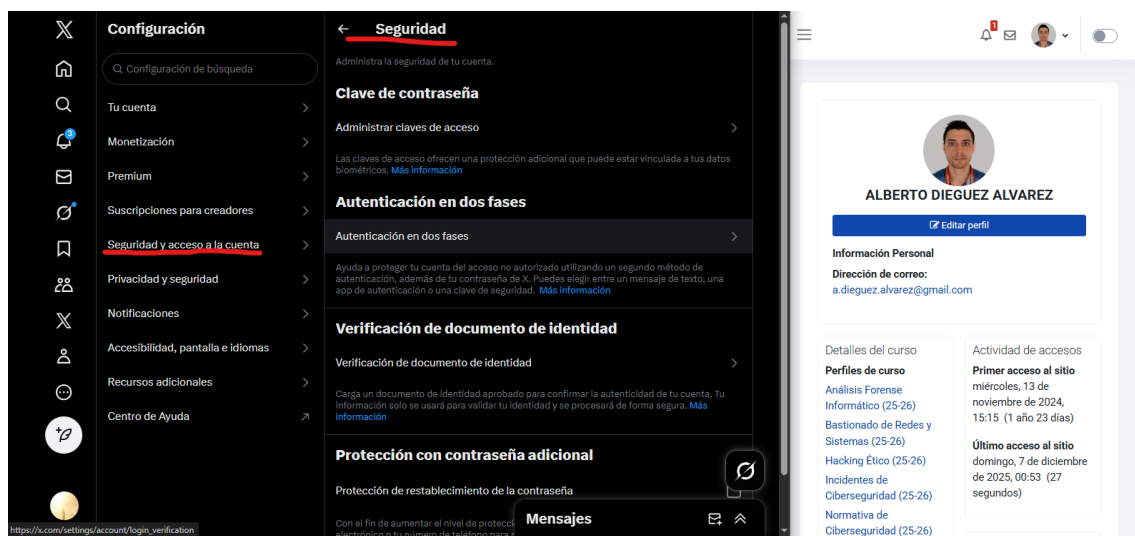
- X:

Activo la autenticación en dos fases con mensaje de texto:

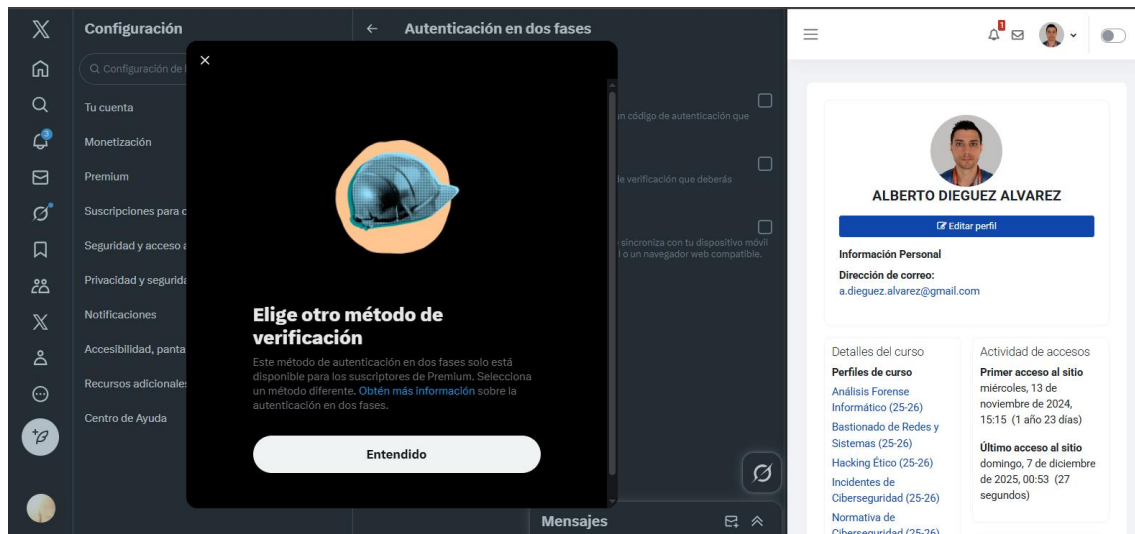
Entro a x.com y me voy a más opciones y configuración de privacidad:



Entro en Seguridad y acceso a la cuenta -> Seguridad y Autenticación en dos fases.

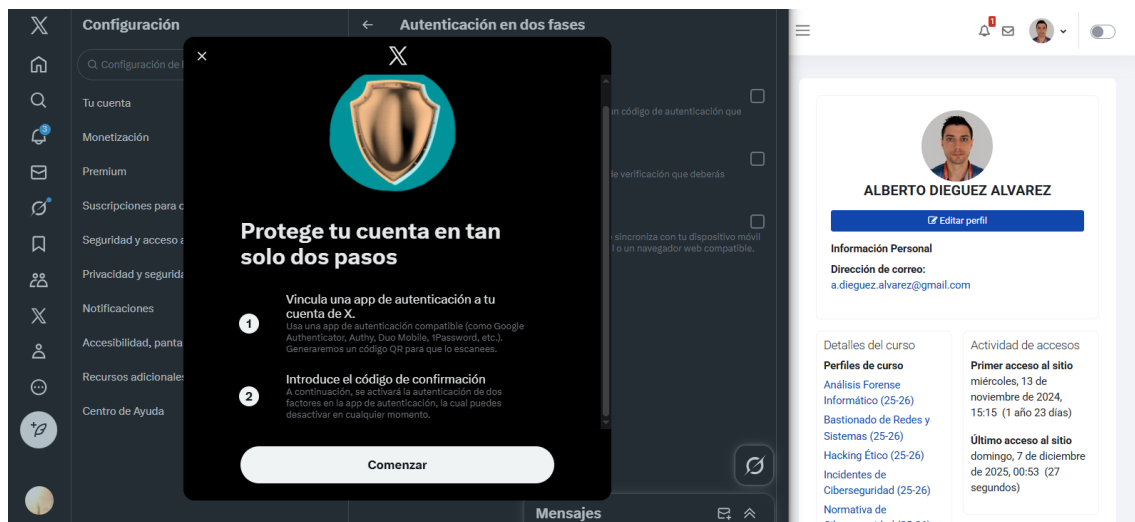


Me encuentro con una sorpresa... esta opción solo está disponible para suscriptores premium.

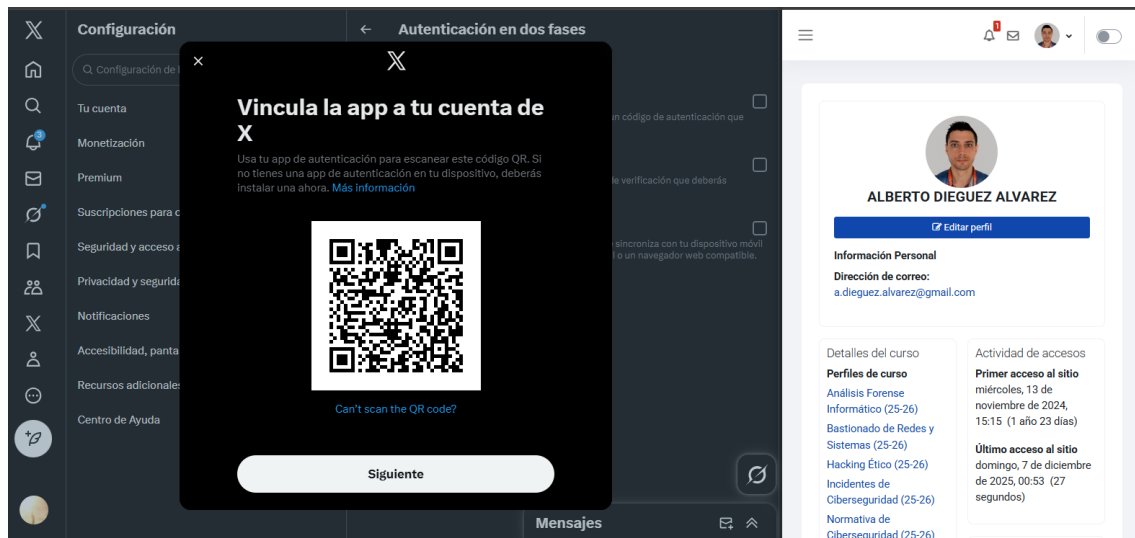


Al final no puedo añadir mi propuesta, así que me propongo a activar la verificación mediante app de autenticación.

Accedo a la configuración:



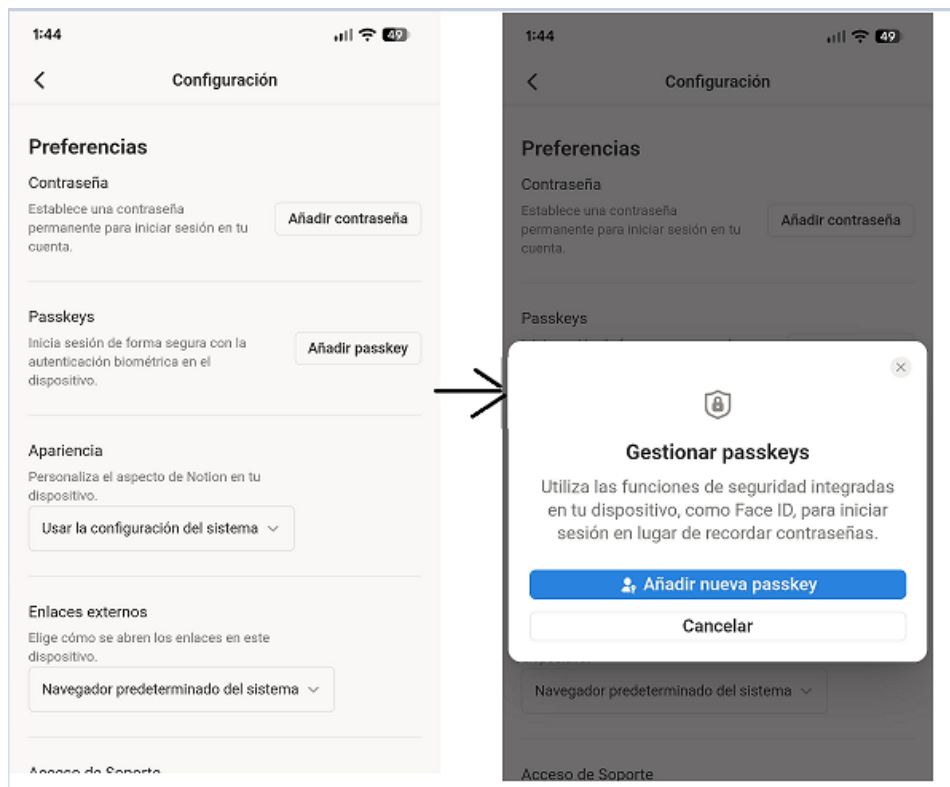
Ahora directamente ya me aparece el QR para asociarlo a mi gestor de autenticación, se escanea y ya estaría listo:



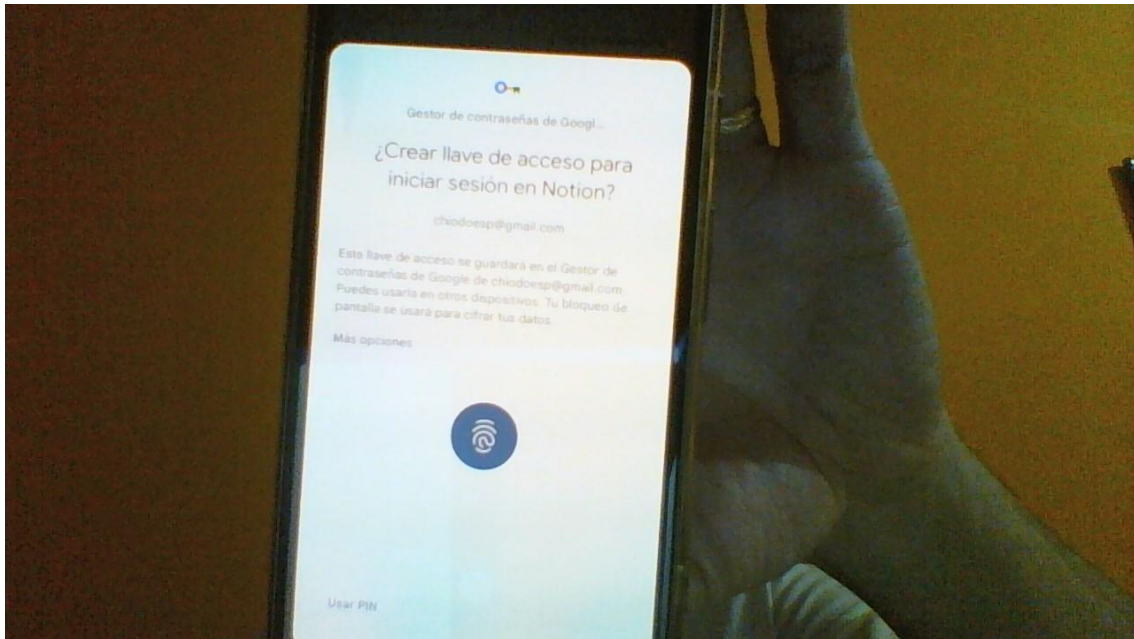
- Notion:

Notion es una app de notas, tareas etc...

Para esta tarea me propongo a activar la biometría para el acceso a la app.



Ahora activo la biometría.



Listo, para acceder a la app lo puedo hacer mediante biometría.

Cualquier dificultad encontrada.

Pues la mas notoria es la de X que directamente parece que algunas opciones de seguridad son de “pago”, el resto no ha tenido mayor dificultad.

Qué información adicional pide el sistema.

En X al activar la autenticación mediante app de autenticación me ha pedido que ingrese mi contraseña actual y además autenticación doble por email con código.

Cómo se comporta si te equivocas o intentas un acceso desde un dispositivo nuevo.

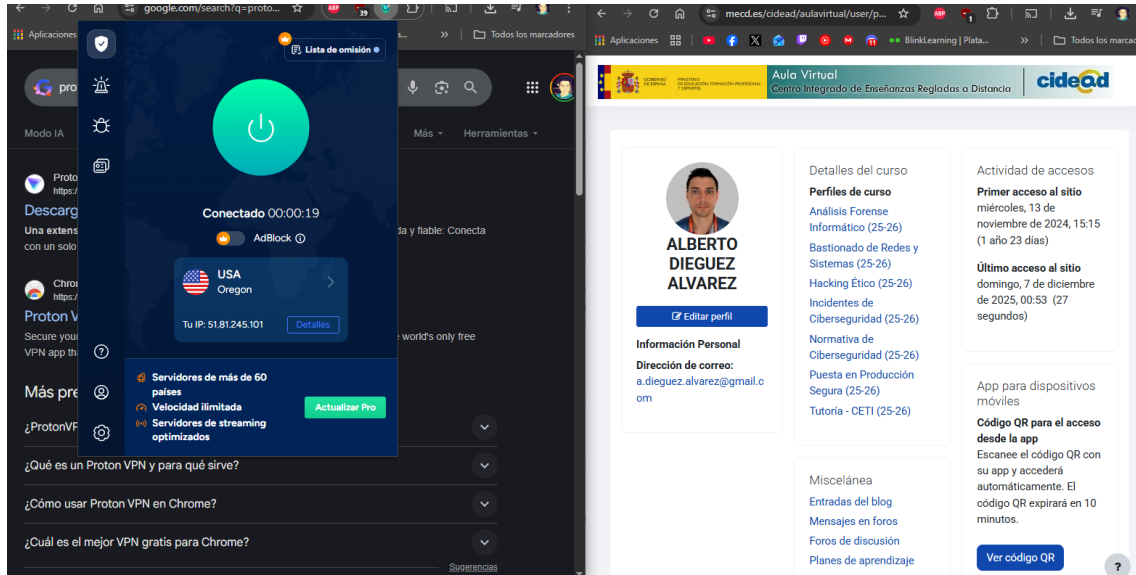
Muchas veces al entrar desde un nuevo dispositivo y desde modo incognito te pide autenticación por código mediante email. Si te confundes simplemente te deniega el acceso, pero nada más.

2. Prueba de comportamiento ante eventos poco comunes

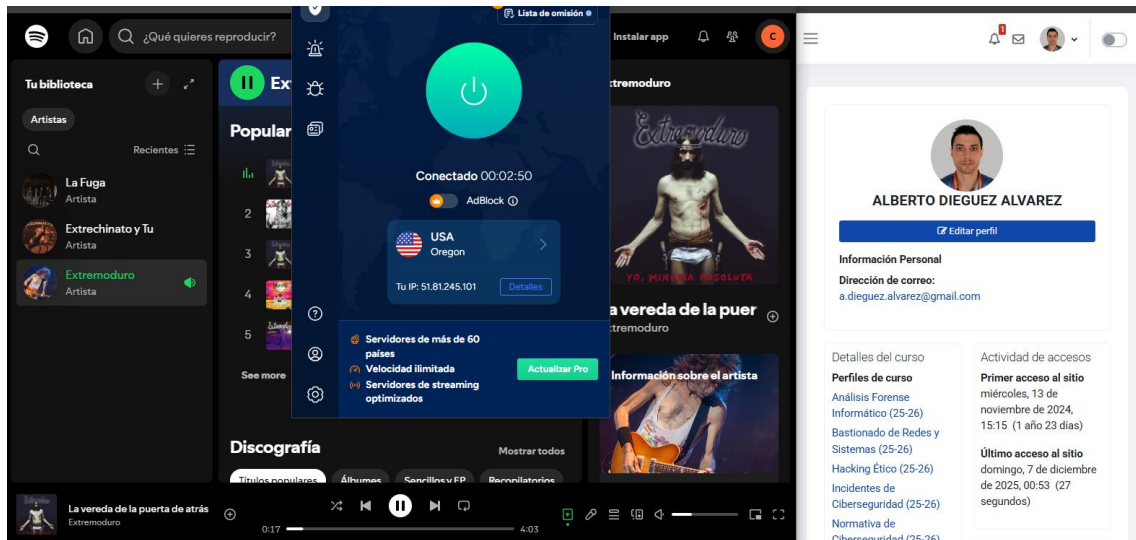
Simula estas tres situaciones:

Acceso desde otro país mediante VPN.

Activa una VPN en EEUU:

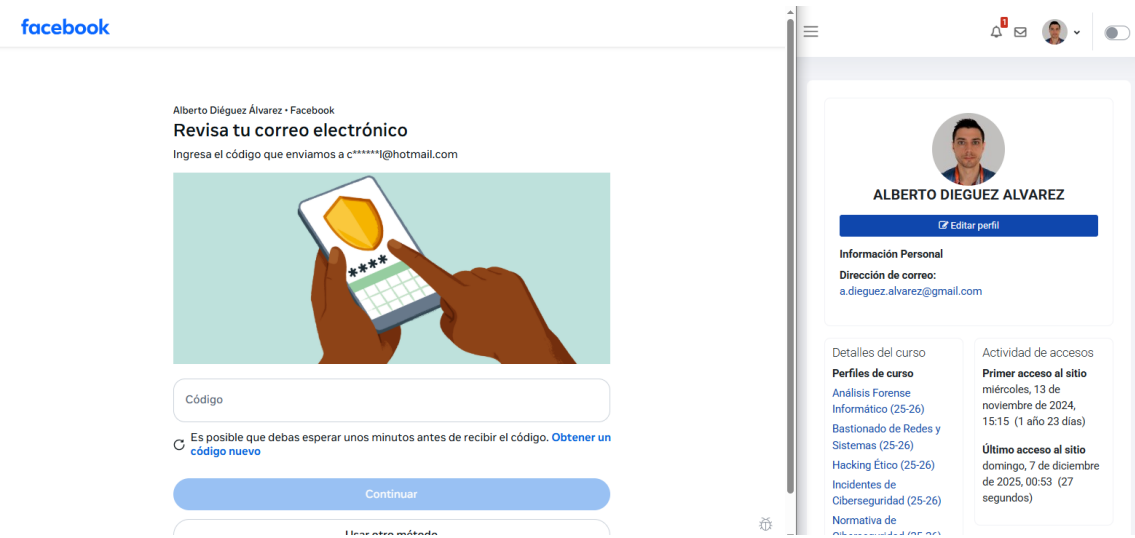


Entro a SpotifyWeb:

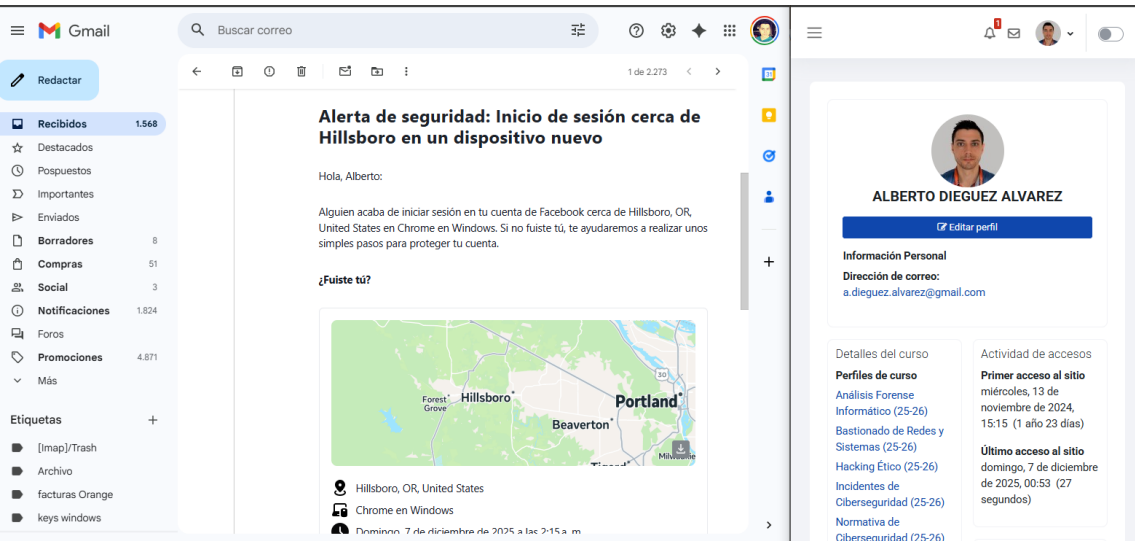


Sin problemas, reproduce canciones normalmente.

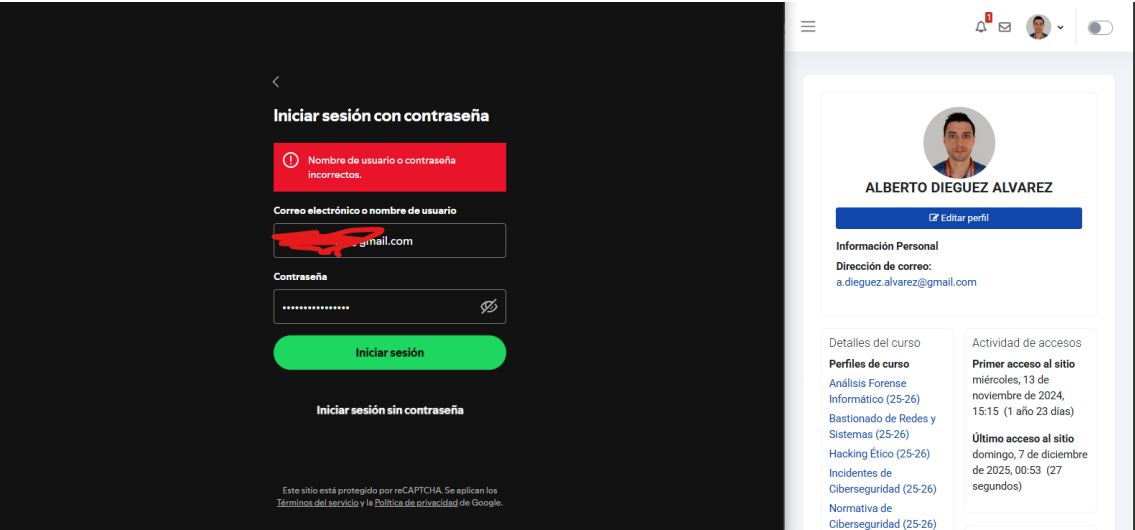
Entro a Facebook:



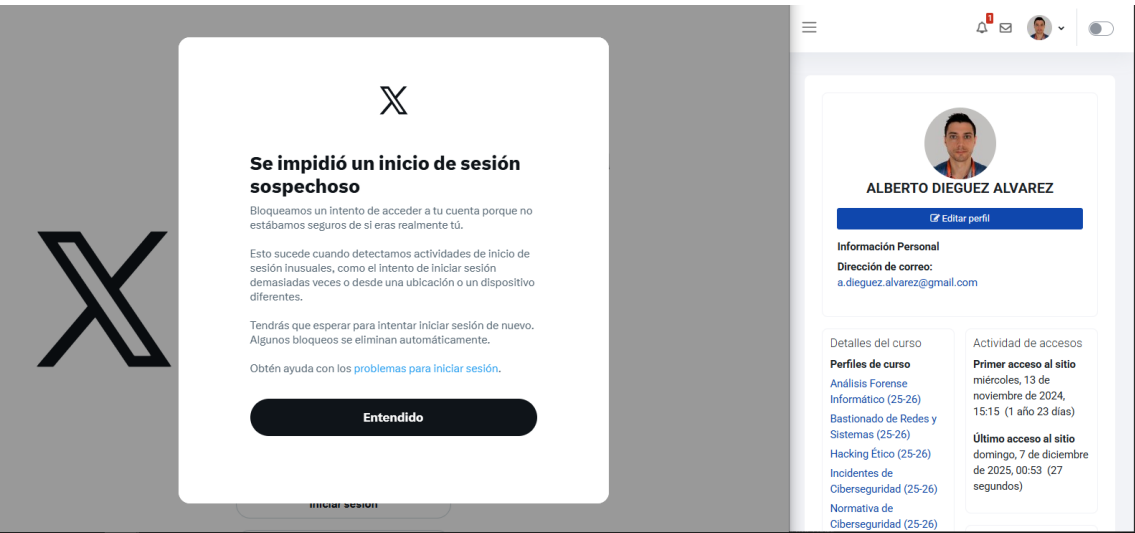
Me solicita código de acceso, y entro sin problemas, pero al pasar unos 2 minutos me llega este email:



Introducción repetida de contraseñas incorrectas.
En Spotify no ocurre nada:

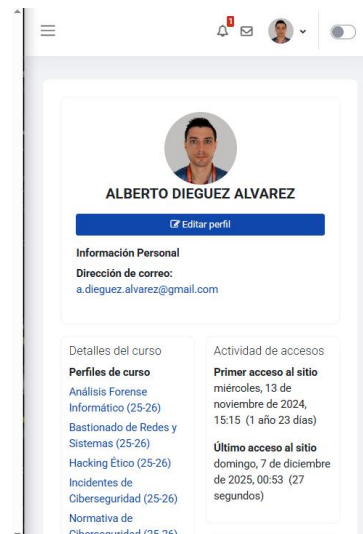
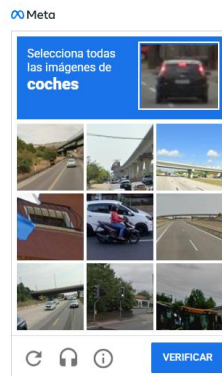


Al intentarlo en X, me salta este aviso.

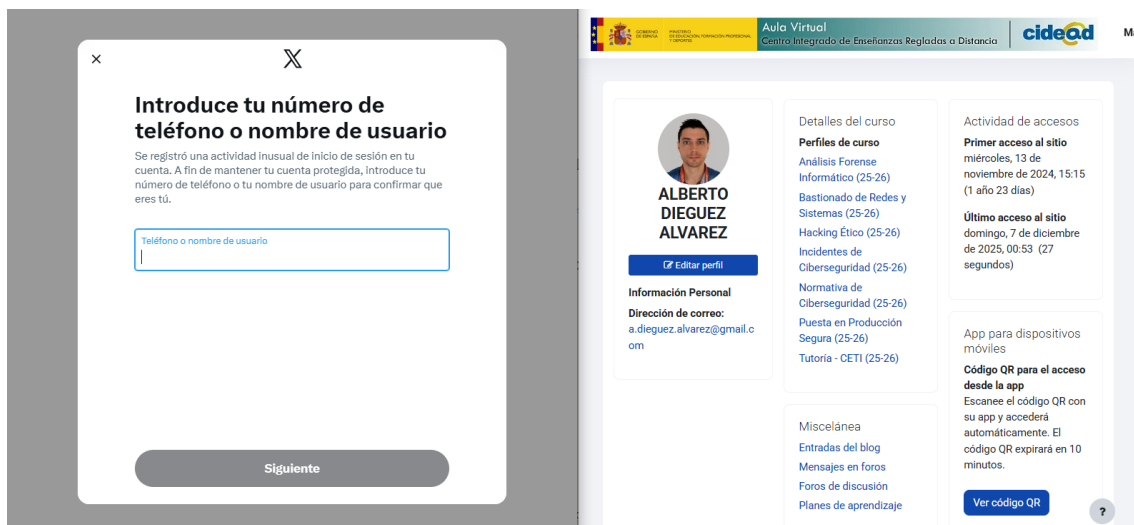


Intento de acceso desde un dispositivo desconocido. Describe la reacción del sistema.
Para cada escenario:

Para Facebook, primero me salta CAPTCHA.



Ahora lo intento en X, después de hacer todas las pruebas anteriores ahora me pide el nombre de usuario o el teléfono móvil.



Pero después entro sin problemas.

Indica si te parece suficiente y por qué.

En global si que me parece suficiente todo lo que ofrecen las diversas apps que he usado, ya que me piden bastante doble autenticación, verificación de datos...

Añade observaciones personales que no se puedan deducir sin hacer la prueba.

La aplicación que mejor gestiona la autenticación bajo mi punto de vista y las pruebas que he hecho es Facebook, me parece que tiene varias opciones y ninguna es de pago.

Me ha sorprendido que X tenga opciones de seguridad básicas de pago.

Apartado 3: Diseño de una propuesta de autenticación para un entorno real

Selecciona o inventa un entorno profesional (empresa, colegio, administración, clínica, etc.) y define:

Pongamos por ejemplo una clínica de fisioterapia, con 1 recepcionista y 5 fisioterapeutas.

Tipos de usuarios.

Tendríamos los **usuarios de la clínica** que tendrían accesos al control de citas ... y por otro lado se podría tener la otra parte, donde el **usuario paciente** pueda iniciar sesión y ver registros de sus citas, lesiones, historial...

Dispositivos utilizados.

Se utiliza un PC por cada empleado, donde cada uno tiene acceso al programa completo donde pueden ver y gestionar las citas, sesiones, historial etc.... Luego los usuarios pueden acceder a su cuenta desde la APP.

Datos sensibles que gestionan.

Los trabajadores gestionan datos de los clientes, como parte de su historial clínico, etc.... Además, depende de cómo se gestione la APP, podría tenerse datos bancarios o de tarjetas de crédito.

Riesgos más probables.

En caso de carecer de un buen sistema de seguridad y una buena capa de ciber seguridad, se podría vulnerar la ley de protección de datos de los clientes, o el robo de datos bancarios etc....

A partir de ello, diseña una propuesta completa de autenticación que incluya:

Qué factores usaría cada tipo de usuario.

Todos los usuarios usarían 2FA tanto por email o por aplicación de autenticación.

Qué factores no usarías y por qué.

No usaría 2FA por SMS o llamada telefónica, por el riesgo de suplantación de identidad mediante SIM swap.

Cómo sería la política de recuperación de acceso.

La recuperación de acceso sería, mediante código de verificación a un email secundario o confirmar la recuperación desde un dispositivo ya verificado.

Para esto sería obligatorio tener un mail principal y otro secundario.

Después para la recuperación se solicitaría una contraseña robusta y que no esté repetida y se cerrarían todas las sesiones activas anteriormente, para asegurar que se restaura desde cero.

Un diagrama sencillo del proceso de autenticación (hecho por ti, a mano o con herramienta).

